

Cadence

Criticita GDPR e piano di adeguamento

Valutazione del codice, dei flussi dati e delle interfacce legali per l'uso della piattaforma con clienti e pazienti nell'Unione europea.

Data	20 luglio 2026
Progetto	Cadence
Ambito	GDPR, cookie, sicurezza, fornitori e diritti
Esito	Non pronto per dati reali

Nota: questo documento è una valutazione tecnica preliminare. La conformità completa dipende anche da contratti, configurazioni dei fornitori, procedure organizzative e dalla verifica di un professionista legale/privacy.

01 Sintesi esecutiva

3 criticità critiche	5 criticità alte	3 criticità medio-alte/medie
--------------------------------	----------------------------	--

Conclusione: Cadence è coerente con un prototipo che usa dati fittizi, ma non deve ancora essere utilizzato in produzione con dati reali di clienti o pazienti. L'attuale disclaimer limita l'uso dichiarato, ma non sostituisce gli obblighi GDPR già applicabili ai dati degli utenti che creano un account.

Le priorità assolute sono:

- eliminare o isolare la demo condivisa e rimuovere gli endpoint legacy pubblici;
- sostituire l'informativa provvisoria con un'informativa completa ai sensi degli artt. 13 e 14;
- definire titolare, responsabile, basi giuridiche e DPA per il trattamento di dati sanitari;
- implementare esportazione, cancellazione definitiva, retention e gestione delle richieste;
- correggere voce, mappe e routing, rendendo trasparenti tutti i destinatari esterni;
- rafforzare RLS, autenticazione, CSP, CORS, audit e risposta agli incidenti.

Controlli positivi già presenti

- la demo locale **/demo** funziona nel browser senza Supabase;
- non sono stati rilevati analytics pubblicitari o tracker di profilazione;
- le chiavi Supabase service-role e OpenRouteService restano server-side;
- l'ottimizzatore verifica l'utente e la proprietà dell'attività;
- la migrazione della route cache abilita e forza RLS;
- il lint del database remoto non ha segnalato errori, solo due warning SQL non di sicurezza.

02 Ambito e mappa dei dati

L'audit ha esaminato il repository locale, le pagine legali, i flussi Supabase, gli endpoint Next.js, la funzione di ottimizzazione, la voce, la geolocalizzazione, le mappe e i meccanismi di cancellazione. Non sono stati modificati file del progetto.

Categoria	Esempi osservati	Sensibilit�
Account professionista	Nome, email, telefono, lingua, fuso orario	Personale
Clienti / pazienti	Nome, contatti, indirizzo, VIP, blacklist, note	Personale / potenzialmente sensibile
Attivit� clinica	Trattamenti, appuntamenti, stato, note, ricorrenze	Possibili dati sanitari art. 9
Posizione	Indirizzi, coordinate, itinerari, geolocalizzazione dispositivo	Personale ad alto impatto
Preferenze	Disponibilit� settimanale, priorit�, lista d'attesa	Personale
Dati tecnici	Sessioni Supabase, cookie tecnici, localStorage, IP presso terzi	Personale / identificatori online
Voce e AI	Audio, trascrizione e testo dettato	Potenzialmente sanitario

Fornitori e destinatari tecnici osservati

- **Supabase:** autenticazione, database, Edge Functions e backup;
- **Vercel:** hosting e log della piattaforma, se il deployment e quello corrente;
- **OpenRouteService / HeiGIT:** geocoding e calcolo delle rotte;
- **OpenStreetMap Foundation:** tile caricati direttamente dal browser;
- **fornitore del browser:** possibile elaborazione remota dell'audio Web Speech;
- **Google Maps / Apple Maps:** ricezione delle coordinate quando l'utente apre la rotta;
- **Gemini / Emergent:** presenti in un endpoint legacy pubblico, anche se non usato dall'interfaccia corrente.

Limite dell'audit: le policy RLS iniziali delle principali tabelle non sono interamente versionate nelle migrazioni disponibili. Il collegamento remoto   stato verificato tramite database lint, ma il dump completo non   stato possibile nell'ambiente di audit. Prima della produzione   necessario eseguire il Supabase Security Advisor.

03 Criticità critiche

01

CRITICA

Informativa privacy provvisoria e incompleta

Evidenza nel progetto

`lib/i18n/extended-dictionaries.ts:229-239` dichiara che l'informativa è un placeholder e non specifica tutti gli elementi obbligatori.

Rischio

L'interessato non riceve informazioni complete su titolare, basi giuridiche, tempi, destinatari, trasferimenti, diritti, reclamo e logica dell'ottimizzatore.

Correzione consigliata

Redigere una vera informativa artt. 13-14 in EN/IT/ES, con identità e indirizzo del titolare, finalità distinte, basi ex art. 6 e 9, retention, sub-responsabili, trasferimenti, diritti, Garante competente e informazioni sull'ottimizzazione automatizzata.

02

CRITICA

Trattamento di dati sanitari senza governance formalizzata

Evidenza nel progetto

Il modello dati include note paziente, piani terapeutici, tipo di trattamento, sedute, disponibilità, appuntamenti e professioni sanitarie.

Rischio

Questi dati possono rientrare nelle categorie particolari dell'art. 9. Un trattamento senza corretta base giuridica, ruoli, istruzioni e misure rafforzate espone a rischio elevato.

Correzione consigliata

Definire il professionista come titolare e Cadence come responsabile; predisporre un DPA art. 28, registro dei trattamenti, istruzioni documentate e basi ex artt. 6 e 9. Svolgere una DPIA prima di un utilizzo su scala o con rischio elevato.

03

CRITICA

Demo completa condivisa e persistente

Evidenza nel progetto

`components/landing/demo-login.tsx:10-36` usa credenziali pubbliche per un unico account Supabase condiviso tra tutti i visitatori.

Rischio

Un utente può inserire dati reali e renderli visibili al visitatore successivo prima del reset. L'account condiviso impedisce inoltre una corretta attribuzione degli accessi.

Correzione consigliata

Mantenere soltanto la demo locale in memoria oppure creare tenant effimeri isolati per sessione, con dati sintetici, scadenza breve e purge automatico. Bloccare campi sensibili e mostrare un avviso persistente.

04 Criticità alte

04

ALTA

Endpoint di reset demo pubblico con privilegi elevati

Evidenza nel progetto

`app/api/demo/reset/route.ts:1-22` invoca una routine che usa la Supabase service-role key, senza autenticazione, autorizzazione o rate limiting.

Rischio

Consente abuso, reset ripetuti, consumo risorse e indisponibilità della demo. Aumenta l'esposizione di una credenziale ad alto privilegio tramite un flusso pubblico.

Correzione consigliata

Eliminare l'endpoint con la demo condivisa oppure proteggerlo con token server-side, rate limit, allowlist e validazione anti-CSRF. Non restituire credenziali nella risposta.

05

ALTA

Endpoint legacy pubblico per MongoDB e Gemini

Evidenza nel progetto

`app/api/[...path]/route.js` espone status Mongo in lettura/scrittura e un parser Gemini/Emergent senza autenticazione.

Rischio

Possibile esfiltrazione dei record status, invio non documentato di testo a un fornitore AI, abuso dei costi e superficie d'attacco non necessaria.

Correzione consigliata

Rimuovere il catch-all se obsoleto. Se serve, separare le route, richiedere autenticazione e business ownership, applicare rate limit, minimizzazione, logging sicuro e contratti con il fornitore.

06

ALTA

Diritti GDPR e cancellazione definitiva assenti

Evidenza nel progetto

`lib/api/patients.ts:246-249` e altre funzioni impostano solo `deleted_at`. Non esistono export o delete account self-service.

Rischio

I dati restano nel database senza un termine definito. Accesso, portabilità, rettifica, limitazione e cancellazione non possono essere gestiti in modo affidabile entro i termini.

Correzione consigliata

Creare export strutturato, cancellazione account e workflow DSAR; aggiungere purge fisico periodico per soft-delete, cache, log e snapshot. Gestire separatamente gli obblighi di conservazione sanitaria e documentare le eccezioni alla cancellazione.

07

ALTA

Header di sicurezza permissivi**Evidenza nel progetto**

next.config.js:37-45 imposta frame-ancestors *, X-Frame-Options ALLOWALL e CORS globale * con metodi e header ampi.

Rischio

Aumenta il rischio di clickjacking, integrazioni non autorizzate e abuso delle API. Per dati sanitari il livello di sicurezza deve essere proporzionato al rischio.

Correzione consigliata

Usare X-Frame-Options DENY o SAMEORIGIN, frame-ancestors 'self', CSP completa, CORS ristretto alle origini necessarie, protezione CSRF e rate limiting sugli endpoint sensibili.

05 Altre criticita

08

ALTA

Autenticazione non adeguata a dati sensibili**Evidenza nel progetto**

La registrazione accetta password di 6 caratteri e non è presente un flusso MFA per gli utenti.

Rischio

Account takeover e accessi non autorizzati possono esporre rubriche, note, trattamenti e posizioni di pazienti.

Correzione consigliata

Richiedere password robuste, breached-password checks, MFA/TOTP, scadenza e revoca sessioni, protezione CAPTCHA/rate limit e audit degli accessi. Applicare RLS a tutte le tabelle pubbliche.

09

MEDIA-ALTA

Indirizzi e coordinate trasmessi a servizi cartografici**Evidenza nel progetto**

app/api/geocode/route.ts e la funzione Edge inviano indirizzi o coordinate a OpenRouteService. Il browser carica tile da OpenStreetMap.

Rischio

Indirizzi di pazienti, studi e percorsi sono dati personali. I destinatari e le finalità non sono indicati nell'informativa; la tile policy OSM vieta dati personali/confidenziali.

Correzione consigliata

Elencare i destinatari, verificare DPA e retention, minimizzare le coordinate, valutare provider UE contrattualizzato o infrastruttura propria. Caricare la mappa solo su richiesta e avvisare prima di aprire Google/Apple Maps.

10

MEDIA-ALTA

Trascrizione vocale descritta in modo potenzialmente fuorviante**Evidenza nel progetto**

lib/voice/use-speech.ts usa Web Speech Recognition. Il testo UI afferma che la trascrizione avviene nel browser, ma in Chrome può essere server-side.

Rischio

Audio e contenuto dettato possono essere trasferiti al fornitore del browser, anche con nomi o informazioni sanitarie, senza indicazione del destinatario.

Correzione consigliata

Usare processLocally quando disponibile; in alternativa mostrare un'informativa prima dell'attivazione, indicare il possibile trasferimento e offrire sempre input testuale. Non descrivere il servizio come esclusivamente locale.

11

MEDIA

Consensi, presa visione e retention tecnica non documentati**Evidenza nel progetto**

La registrazione combina termini e privacy in una checkbox senza registrare versione/data. La route cache scade logicamente ma non viene eliminata; coordinate a 5 decimali sono quasi esatte.

Rischio

La prova dell'accettazione contrattuale è debole; un eventuale consenso non sarebbe separato e revocabile. Cache e coordinate possono restare oltre il necessario.

Correzione consigliata

Separare termini, presa visione privacy e consensi opzionali; registrare versione e timestamp. Definire retention per categoria, purge automatico e precisione geografica minima necessaria.

06 Cookie, storage e fornitori

Stato attuale dei cookie

Tecnologia	Finalita	Consenso
Cookie Supabase Auth	Sessione e autenticazione	Normalmente tecnico
sidebar_state	Preferenza apertura sidebar, 7 giorni	Preferenza/tecnico; informativa
localStorage lingua/tema	Personalizzazione interfaccia	Normalmente non profilante
localStorage calendario	Vista, densita e layout	Funzionale

Conclusione cookie: non sono stati rilevati Google Analytics, Meta Pixel, PostHog o tracker pubblicitari. Se il sito mantiene soltanto cookie tecnici e preferenze funzionali, un banner di consenso non e automaticamente necessario; serve comunque una sezione cookie/storage nell'informativa. Qualunque analytics o profilazione futura deve restare bloccata fino al consenso.

Contratti e verifiche necessarie

- accettare e archiviare il DPA Supabase; verificare regione database UE, backup e sub-responsabili;
- verificare che il piano Vercel usato sia coperto dal relativo DPA e dalle SCC applicabili;
- chiarire se HeiGIT/OpenRouteService offre un rapporto art. 28 adeguato per indirizzi di pazienti;
- documentare OpenStreetMap, Google Maps, Apple Maps e il fornitore della trascrizione vocale;
- mantenere un registro aggiornato di sub-responsabili e notificare le modifiche ai clienti.

I trasferimenti fuori dallo SEE richiedono decisione di adeguatezza o garanzie appropriate, come SCC, oltre alla valutazione concreta dei trasferimenti e all'informazione agli interessati.

07 Piano di adeguamento

Fase	Interventi	Uscita attesa
0 - Immediata Prima di altri test pubblici	Disabilitare demo condivisa e endpoint legacy; vietare dati reali; correggere CORS/CSP; rate limit reset e auth; verificare RLS con Security Advisor.	Nessuna esposizione evidente di dati tra visitatori.
1 - Beta chiusa Governance	Informativa completa; DPA clienti; registro trattamenti; vendor DPAs; basi art. 6/9; versionamento termini; procedura DSAR e data breach.	Documentazione e responsabilit� definite.
2 - Prodotto Diritti e retention	Export, delete account, hard purge, retention per categoria, gestione backup, rettifica, limitazione e portabilit�.	Diritti esercitabili e dati non conservati indefinitamente.
3 - Dati sanitari Hardening	DPIA; MFA; audit accessi; separazione ruoli; session timeout; backup testati; cifratura; penetration test; incident response e formazione.	Rischio residuo documentato e accettabile.
4 - Go-live Revisione indipendente	Revisione legale italiana/UE, test sicurezza indipendente, verifica fornitori e approvazione finale di titolare e responsabile.	Decisione formale di messa in produzione.

Checklist minima prima di usare dati reali

- informativa artt. 13-14 pubblicata e coerente con i flussi effettivi;
- DPA art. 28 disponibile ai clienti professionali;
- basi giuridiche art. 6 e 9 definite e documentate;
- RLS verificata su ogni tabella e funzione accessibile al client;
- MFA, password robuste, rate limit, CSP e CORS restrittivi;
- export, rettifica, cancellazione, portabilit  e gestione richieste operative;
- retention e purge automatici testati, compresi cache, log e backup;
- DPIA approvata quando richiesta e procedura data breach entro 72 ore;
- fornitori, regioni e trasferimenti documentati;
- demo e ambienti di test isolati, con soli dati sintetici.

08 Fonti e riferimenti

1. [Commissione europea - Informazioni da fornire agli interessati](https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations/principles-gdpr/what-information-must-be-given-individuals-whose-data-collected_en)
https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations/principles-gdpr/what-information-must-be-given-individuals-whose-data-collected_en
2. [Commissione europea - Dati personali sensibili e dati sanitari](https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations/legal-grounds-processing-data/sensitive-data/what-personal-data-considered-sensitive_en)
https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations/legal-grounds-processing-data/sensitive-data/what-personal-data-considered-sensitive_en
3. [Commissione europea - Quando e richiesta una DPIA](https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations/obligations/when-data-protection-impact-assessment-dpia-required_en)
https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations/obligations/when-data-protection-impact-assessment-dpia-required_en
4. [Commissione europea - Diritti degli interessati](https://commission.europa.eu/law/law-topic/data-protection/information-individuals_en)
https://commission.europa.eu/law/law-topic/data-protection/information-individuals_en
5. [Commissione europea - Data breach e termine di 72 ore](https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations/obligations/what-data-breach-and-what-do-we-have-do-case-data-breach_en)
https://commission.europa.eu/law/law-topic/data-protection/rules-business-and-organisations/obligations/what-data-breach-and-what-do-we-have-do-case-data-breach_en
6. [EDPB - Sicurezza dei dati personali](https://www.edpb.europa.eu/sme/be-compliant/secure-personal-data_en)
https://www.edpb.europa.eu/sme/be-compliant/secure-personal-data_en
7. [EDPB - Basi giuridiche del trattamento](https://www.edpb.europa.eu/sme/be-compliant/process-personal-data-lawfully_en)
https://www.edpb.europa.eu/sme/be-compliant/process-personal-data-lawfully_en
8. [Garante per la protezione dei dati personali - FAQ cookie](https://garanteprivacy.it/faq/cookie)
<https://garanteprivacy.it/faq/cookie>
9. [OpenStreetMap Foundation - Tile Usage Policy](https://operations.osmfoundation.org/policies/tiles/)
<https://operations.osmfoundation.org/policies/tiles/>
10. [MDN - SpeechRecognition e riconoscimento server-side](https://developer.mozilla.org/en-US/docs/Web/API/SpeechRecognition)
<https://developer.mozilla.org/en-US/docs/Web/API/SpeechRecognition>
11. [Supabase - Production Checklist](https://supabase.com/docs/guides/deployment/going-into-prod)
<https://supabase.com/docs/guides/deployment/going-into-prod>
12. [Supabase - Data Processing Addendum](https://supabase.com/downloads/docs/Supabase%2BDPA%2B260601.pdf)
<https://supabase.com/downloads/docs/Supabase%2BDPA%2B260601.pdf>
13. [Vercel - Data Processing Addendum](https://vercel.com/legal/dpa)
<https://vercel.com/legal/dpa>
14. [Commissione europea - Trasferimenti internazionali](https://commission.europa.eu/law/law-topic/data-protection/information-business-and-organisations/obligations/what-rules-apply-if-my-organisation-transfers-data-outside-eu_en)
https://commission.europa.eu/law/law-topic/data-protection/information-business-and-organisations/obligations/what-rules-apply-if-my-organisation-transfers-data-outside-eu_en

Prossimo passo consigliato

Trasformare questo audit in un backlog tecnico separato dal lavoro corrente, partendo da demo condivisa, endpoint legacy, header di sicurezza e RLS. Solo dopo procedere con informativa, DPA, retention e DPIA.